

HELIX

Cybersecurity Operations Platform

PoC Engineering Roadmap

Learn & Build Hybrid Approach

Document Type	Engineering Roadmap
Project Phase	Proof of Concept (PoC)
Document Version	2.0
Academic Year	2025 – 2026
Author	Yasseene
Classification	Academic – Confidential

Contents

Introduction	3
Architecture Reference	4
Global Phase Map	5
1 PHASE 0 – Project Setup, Git Workflow & Development Environment	6
1.1 0.1 – Git Repository Setup	7
1.2 0.2 – Apache Vhost Configuration (Fedora/RHEL)	7
1.3 0.3 – MySQL Setup	9
1.4 0.4 – PHP Composer Setup	10
1.5 0.5 – Environment Configuration	10
1.6 0.6 – Database Config	12
1.7 0.7 – CORS Configuration	12
1.8 0.8 – Helper Classes	13
1.9 0.9 – Front Controller Bootstrap	15
1.10 0.10 – Python Environment	16
1.11 0.11 – Java Environment	16
2 PHASE 1 – Architecture Design, Database Schema & UML	18
2.1 1.1 – Database Schema	19
2.2 1.2 – API Route Contract	20
2.3 1.3 – UML Diagram Validation	21
2.4 1.4 – SRS Traceability Matrix	22
2.5 1.5 – Seed File	22
3 PHASE 2 – Authentication Module (FR-001 to FR-007)	24
3.1 2.1 – Auth Middleware	25
3.2 2.2 – User Model	26
3.3 2.3 – Auth Service	27
3.4 2.4 – Auth Controller	28
3.5 2.5 – Register Auth Routes	30
3.6 2.6 – Frontend: Login Page	30
3.7 2.7 – Auth Tests	31
3.8 2.8 – Manual Test Checklist	32
4 PHASE 3 – Dashboard Module (FR-010 to FR-014)	34
4.1 3.1 – Client-Side Router	35
4.2 3.2 – Dashboard Shell	35
4.3 3.3 – Dashboard Stats Endpoint	37

4.4 3.4 – Dashboard Frontend Module 38

5 PHASE 4 through PHASE 10 – Implementation Phases 41

Conclusion 42

Introduction

This document is your personal engineering execution blueprint, adapted to your actual project architecture: a decoupled SPA frontend, a layered PHP API (Controller → Service → Model), a Python ML module, and a Java utility module. Every file reference in this roadmap maps to a real file in your tree. Follow it sequentially, create files only when you reach them, and mark your progress as you go.

How to Use This Roadmap

[x] Not started	Mark as completed when done
[] In progress	Currently working on
[] Completed	Task finished
[!] Blocked	Needs review or unblocking

You do not move to the next phase until the current phase's **Definition of Done** is satisfied. You create files only when you need them – not before.

Architecture Reference

Before starting, internalize this flow. Every feature you build will follow it:

```
Browser (frontend/)
|
|  HTTP fetch() via api.js
v
api/index.php          <- Front Controller: parses route, applies middleware, dispatches
|
|-- middleware/AuthMiddleware.php    <- Is the user logged in?
|-- middleware/RoleMiddleware.php    <- Is the user allowed?
|
v
api/controllers/XController.php      <- Parse request, call service, return response
|
v
api/services/XService.php            <- All business logic lives here
|
v
api/models/X.php                  <- All DB queries live here (PDO)
|
v
MySQL (helix_db)
```

Key architectural decisions already made:

- The frontend is completely decoupled – it never touches PHP directly
- `api/index.php` is the single entry point – all routes go through it
- `api/config/Cors.php` handles CORS because frontend and API are on different paths
- `api/helpers/Response.php` standardizes all JSON responses
- `api/helpers/Validator.php` centralizes input validation
- `api/services/JavaBridge.php` is the only place that touches `shell_exec()`

Global Phase Map

PHASE 0	-> PHASE 1	-> PHASE 2	-> PHASE 3	-> PHASE 4	-> PHASE 5	-> PHASE 6	-> PHASE 7	-> PHASE 8
Setup & Git	Architecture & DB Design	Auth + RBAC	Dashboard & Routing	Log Ingestion	Alert Module	ML Detection	AI Assistant	Scan Modu

Dependency chain (strict):

- Phase 1 requires Phase 0
- Phase 2 requires Phase 1 (DB schema + routing foundation in place)
- Phase 3 requires Phase 2 (auth middleware working, frontend routing exists)
- Phase 4 requires Phase 3 (dashboard shell exists as UI home)
- Phase 5 requires Phase 4 (log data is the raw input for alerts + ML)
- Phase 6 requires Phase 5 (alerts are generated from scored logs)
- Phase 7 requires Phase 5 (ML needs log data to score)
- Phase 8 requires Phase 6 (AI analyzes alerts enriched by ML scores)
- Phase 9 requires Phase 2 (scanner only needs auth, independent of logs/ML)
- Phase 10 requires Phases 2–9 (all modules complete and individually tested)
- Phase 11 requires Phase 10 (containerize only a stable application)

1. PHASE 0 – Project Setup, Git Workflow & Development Environment

Phase 0: Setup & Environment

Why this comes first: Without a reproducible environment and version control, everything you build is fragile. One wrong XAMPP config, one missing `.gitignore`, and you lose hours. This phase costs 2 hours and saves 20.

Objective

Establish the complete development environment, Git discipline, Apache serving strategy, Composer setup, and Python environment – before writing a single line of application logic.

Learning Goals

- Understand Git branching strategy for solo development
- Understand how Apache serves two directories under one vhost (frontend + api)
- Understand Composer as PHP's dependency manager and autoloader
- Understand `pyproject.toml` vs `requirements.txt` (and why you're using the former)
- Understand the Front Controller pattern (`api/index.php`)

Key Theoretical Concepts

- **Git Flow (simplified):** `main` = stable releases, `dev` = integration branch, `feature/*` = active work
- **Apache vhost + Alias directive:** How to serve `frontend/` at `/` and `api/` at `/api` from one domain
- **Composer autoloading (PSR-4):** How use `App\Controllers\AuthController` resolves to a file path automatically
- **Front Controller:** One entry point that routes all requests – no 30 separate PHP files each handling their own routing

- **CORS (Cross-Origin Resource Sharing):** Why the browser blocks your `fetch('/api/...')` without the right headers

1.1 0.1 – Git Repository Setup

[x] Create private repository on GitHub/GitLab

[x] Clone locally into your project root

[x] Create `.gitignore`:

```
1 # PHP
2 vendor/
3 composer.lock (optional)
4
5 # Python
6 python-module/.venv/
7 python-module/__pycache__/
8 python-module/models/*.joblib
9
10 # Java
11 java-module/build/*.class
12
13 # Environment
14 api/config/.env
15 .env
16
17 # IDE
18 .vscode/
19 .idea/
20 *.DS_Store
```

[] Create `CHANGELOG.md` – update at end of every phase

[] Initial commit: `git commit -m "chore: initialize HELIX project"`

[] Create dev branch: `git checkout -b dev`

Branching strategy:

- Work on `feature/*` branches cut from `dev`
- Merge `feature/*` → `dev` when a phase is complete and tested
- Merge `dev` → `main` only when a full milestone works end-to-end

1.2 0.2 – Apache Vhost Configuration (Fedora/RHEL)

This is the critical decision from the review. You have `frontend/` and `api/` as siblings. Define how Apache serves both under `helix.local`. On Fedora, Apache config lives in `/etc/httpd/`.

Step 1: Install Apache, PHP, and dependencies

```
1 sudo dnf install httpd php php-cli
2 sudo dnf install php-pdo php-pdo_mysql php-json
3 sudo systemctl start httpd
4 sudo systemctl enable httpd
```

Verify Apache is running: `curl http://localhost`

Step 2: Create vhost configuration

Create `/etc/httpd/conf.d/helix.conf` (requires `sudo`):

```
1 <VirtualHost *:80>
2     ServerName helix.local
3     DocumentRoot /home/yasseene/HELIX/frontend
4
5     <Directory /home/yasseene/HELIX/frontend>
6         Options Indexes FollowSymLinks
7         AllowOverride All
8         Require all granted
9
10    <IfModule mod_rewrite.c>
11        RewriteEngine On
12        RewriteBase /
13        RewriteCond %{REQUEST_FILENAME} !-f
14        RewriteCond %{REQUEST_FILENAME} !-d
15        RewriteRule ^(.*)$ index.html [QSA,L]
16    </IfModule>
17 </Directory>
18
19 Alias /api /home/yasseene/HELIX/api
20
21 <Directory /home/yasseene/HELIX/api>
22     Options FollowSymLinks
23     AllowOverride All
24     Require all granted
25
26     <IfModule mod_rewrite.c>
27         RewriteEngine On
28         RewriteBase /api
29         RewriteCond %{REQUEST_FILENAME} !-f
30         RewriteCond %{REQUEST_FILENAME} !-d
31         RewriteRule ^(.*)$ index.php?path=$1 [QSA,L]
32     </IfModule>
33 </Directory>
34
35 <FilesMatch \.php$>
36     SetHandler application/x-httpd-php
37 </FilesMatch>
38
39 ErrorLog /var/log/httpd/helix_error.log
40 CustomLog /var/log/httpd/helix_access.log combined
41 </VirtualHost>
```

Step 3: Enable `mod_rewrite`

On Fedora/RHEL, `mod_rewrite` is usually enabled by default. Verify:

```
1 grep -i "rewrite" /etc/httpd/conf.modules.d/*.conf
```

Step 4: Add to system hosts file

```
1 echo "127.0.0.1    helix.local" | sudo tee -a /etc/hosts
2 ping helix.local
```

Step 5: Fix file permissions

```
1 sudo usermod -a -G $(id -gn) apache
2 chmod 755 /home/yasseene/HELIX
3 chmod 755 /home/yasseene/HELIX/{frontend,api}
```

Step 6: Validate and restart Apache

```
1 sudo httpd -t
2 sudo systemctl restart httpd
3 sudo systemctl status httpd
```

Consequence for `api.js`: All frontend API calls will use:

```
1 const API_BASE = "/api"; // relative -- works on same origin
```

Never hardcode `http://localhost/...` – relative paths survive domain changes.

- [x] Install Apache, PHP, and dependencies
- [x] Create `/etc/httpd/conf.d/helix.conf` with vhost above
- [x] Add `127.0.0.1 helix.local` to `/etc/hosts`
- [x] Fix permissions
- [x] Verify `mod_rewrite`
- [x] Run `sudo httpd -t` (syntax check)
- [x] Run `sudo systemctl restart httpd`
- [x] Verify: `http://helix.local` serves `frontend/index.html`
- [x] Create `api/index.php` with `echo "API OK"`; temporarily
- [x] Verify: `http://helix.local/api` returns "API OK"
- [x] Check logs: `tail -f /var/log/httpd/helix_error.log` if anything fails

1.3 0.3 – MySQL Setup

- [x] Start MySQL in XAMPP

[x] Create database: `helix_db`

[x] Create dedicated user with limited privileges:

```
1 CREATE USER 'helix_user'@'localhost' IDENTIFIED BY 'your_password';
2 GRANT SELECT, INSERT, UPDATE, DELETE ON helix_db.* TO 'helix_user'@'
  localhost';
3 FLUSH PRIVILEGES;
```

[] Verify connection via phpMyAdmin

1.4 0.4 – PHP Composer Setup

`composer.json`:

```
1 {
2     "name": "helix/api",
3     "description": "HELIX Cybersecurity Platform API",
4     "type": "project",
5     "require": {
6         "php": ">=8.1"
7     },
8     "require-dev": {
9         "phpunit/phpunit": "~10.0"
10    },
11    "autoload": {
12        "psr-4": {
13            "App\\": "api/"
14        }
15    },
16    "autoload-dev": {
17        "psr-4": {
18            "Tests\\": "tests/php/"
19        }
20    }
21 }
```

[] Run: `composer install`

[] Verify `vendor/autoload.php` was created

[] Add `require_once __DIR__ . '/../../vendor/autoload.php';` to `api/index.php`

Why PSR-4 matters: With this config, use `App\Controllers\AuthController` automatically maps to `api/controllers/AuthController.php`. You never write manual `require` statements for your own classes.

1.5 0.5 – Environment Configuration

`api/config/Environment.php`:

```

1 <?php
2 namespace App\Config;
3
4 class Environment
5 {
6     private static array $vars = [];
7
8     public static function load(string $envFile): void
9     {
10         if (!file_exists($envFile)) return;
11
12         foreach (file($envFile, FILE_IGNORE_NEW_LINES |
13             FILE_SKIP_EMPTY_LINES) as $line) {
14             if (str_starts_with(trim($line), '#')) continue;
15             [$key, $value] = explode('=', $line, 2);
16             self::$vars[trim($key)] = trim($value);
17             $_ENV[trim($key)] = trim($value);
18         }
19
20     public static function get(string $key, mixed $default = null): mixed
21     {
22         return self::$vars[$key] ?? $_ENV[$key] ?? getenv($key) ??
23             $default;
24     }
25 }

```

Create api/config/.env (gitignored):

```

1 DB_HOST=localhost
2 DB_NAME=helix_db
3 DB_USER=helix_user
4 DB_PASS=your_password
5 OPENAI_API_KEY=sk-...
6 SESSION_LIFETIME=3600
7 PYTHON_PATH=C:/path/to/.venv/Scripts/python.exe
8 PYTHON_SCRIPT=python-module/anomaly_detector.py
9 JAVA_BUILD_PATH=java-module/build

```

Create api/config/.env.example (committed to git – no real values):

```

1 DB_HOST=localhost
2 DB_NAME=helix_db
3 DB_USER=helix_user
4 DB_PASS=
5 OPENAI_API_KEY=
6 SESSION_LIFETIME=3600
7 PYTHON_PATH=
8 PYTHON_SCRIPT=python-module/anomaly_detector.py
9 JAVA_BUILD_PATH=java-module/build

```

1.6 0.6 – Database Config

api/config/Database.php:

```

1  <?php
2  namespace App\Config;
3
4  use PDO;
5  use PDOException;
6
7  class Database
8  {
9      private static ?PDO $instance = null;
10
11     public static function getInstance(): PDO
12     {
13         if (self::$instance === null) {
14             $host = Environment::get('DB_HOST', 'localhost');
15             $name = Environment::get('DB_NAME');
16             $user = Environment::get('DB_USER');
17             $pass = Environment::get('DB_PASS');
18
19             $dsn = "mysql:host={$host};dbname={$name};charset=utf8mb4";
20             $options = [
21                 PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
22                 PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
23                 PDO::ATTR_EMULATE_PREPARES => false,
24             ];
25
26             try {
27                 self::$instance = new PDO($dsn, $user, $pass, $options);
28             } catch (PDOException $e) {
29                 error_log("DB connection failed: " . $e->getMessage());
30                 http_response_code(500);
31                 echo json_encode(['error' => 'Database unavailable']);
32                 exit;
33             }
34         }
35
36         return self::$instance;
37     }
38 }

```

[] Test: add a Database::getInstance(); call to api/index.php temporarily → no error

1.7 0.7 – CORS Configuration

api/config/Cors.php:

```

1  <?php
2  namespace App\Config;
3

```

```

4 class Cors
5 {
6     public static function handle(): void
7     {
8         $allowedOrigins = ['http://helix.local', 'http://localhost'];
9         $origin = $_SERVER['HTTP_ORIGIN'] ?? '';
10
11         if (in_array($origin, $allowedOrigins, true)) {
12             header("Access-Control-Allow-Origin: {$origin}");
13         }
14
15         header('Access-Control-Allow-Methods: GET, POST, PUT, DELETE,
16             OPTIONS');
17         header('Access-Control-Allow-Headers: Content-Type, Authorization,
18             X-Requested-With');
19         header('Access-Control-Allow-Credentials: true');
20
21         if ($_SERVER['REQUEST_METHOD'] === 'OPTIONS') {
22             http_response_code(204);
23             exit;
24         }
25     }
26 }

```

1.8 0.8 – Helper Classes

api/helpers/Response.php:

```

1 <?php
2 namespace App\Helpers;
3
4 class Response
5 {
6     public static function json(mixed $data, int $status = 200): void
7     {
8         http_response_code($status);
9         header('Content-Type: application/json');
10        echo json_encode($data);
11        exit;
12    }
13
14    public static function success(mixed $data = null, string $message = '
15        OK', int $status = 200): void
16    {
17        self::json(['success' => true, 'message' => $message, 'data' =>
18            $data], $status);
19    }
20
21    public static function error(string $message, int $status = 400): void
22    {
23        self::json(['success' => false, 'error' => $message], $status);
24    }
25 }

```

```
22     }
23
24     public static function unauthorized(): void
25     {
26         self::error('Unauthorized', 401);
27     }
28
29     public static function forbidden(): void
30     {
31         self::error('Forbidden', 403);
32     }
33 }
```

api/helpers/Validator.php:

```
1  <?php
2  namespace App\Helpers;
3
4  class Validator
5  {
6      private array $errors = [];
7
8      public function required(string $field, mixed $value): self
9      {
10         if (empty($value) && $value !== '0') {
11             $this->errors[$field] = "{$field} is required";
12         }
13         return $this;
14     }
15
16     public function email(string $field, mixed $value): self
17     {
18         if (!filter_var($value, FILTER_VALIDATE_EMAIL)) {
19             $this->errors[$field] = "{$field} must be a valid email";
20         }
21         return $this;
22     }
23
24     public function minLength(string $field, mixed $value, int $min): self
25     {
26         if (strlen((string)$value) < $min) {
27             $this->errors[$field] = "{$field} must be at least {$min}
28                 characters";
29         }
30         return $this;
31     }
32
33     public function passes(): bool
34     {
35         return empty($this->errors);
36     }
37
38     public function errors(): array
```

```

38     {
39         return $this->errors;
40     }
41 }

```

1.9 0.9 – Front Controller Bootstrap

api/index.php – the single entry point for all API calls:

```

1  <?php
2  declare(strict_types=1);
3
4  require_once __DIR__ . '/../vendor/autoload.php';
5
6  use App\Config\Environment;
7  use App\Config\Cors;
8  use App\Helpers\Response;
9
10 // 1. Load environment
11 Environment::load(__DIR__ . '/config/.env');
12
13 // 2. Handle CORS (must be before any output)
14 Cors::handle();
15
16 // 3. Parse route
17 $method = $_SERVER['REQUEST_METHOD'];
18 $uri     = parse_url($_SERVER['REQUEST_URI'], PHP_URL_PATH);
19
20 // Strip /api prefix (added by Apache Alias)
21 $uri = preg_replace('#~/api#', '', $uri);
22 $uri = rtrim($uri, '/') ?: '/';
23
24 // 4. Route dispatch (will grow with each phase)
25 $routes = [];
26
27 // Each phase will add routes here:
28 // $routes['POST']['/auth/login'] = [AuthController::class, 'login'];
29
30 // 5. Dispatch
31 if (isset($routes[$method][$uri])) {
32     [$controllerClass, $action] = $routes[$method][$uri];
33     $controller = new $controllerClass();
34     $controller->$action();
35 } else {
36     Response::error('Route not found', 404);
37 }

```

[] Verify: `http://helix.local/api/nonexistent` returns `{"success":false,"error":"Route not found"}`

1.10 0.10 – Python Environment

[] Confirm Python ≥ 3.10 : `python -version`

[] Create virtual environment inside `python-module/`:

```
1 cd python-module
2 python -m venv .venv
```

[] Create `pyproject.toml`:

```
1 [project]
2 name = "helix-python-module"
3 version = "0.1.0"
4 description = "Isolation Forest anomaly detection for HELIX"
5 requires-python = ">=3.10"
6
7 [project.dependencies]
8 scikit-learn = ">=1.3.0"
9 pandas = ">=2.0.0"
10 numpy = ">=1.24.0"
11 joblib = ">=1.3.0"
12 mysql-connector-python = ">=8.0.0"
13
14 [project.optional-dependencies]
15 dev = [
16     "pytest>=7.0.0",
17 ]
18
19 [build-system]
20 requires = ["setuptools>=68.0"]
21 build-backend = "setuptools.backends.legacy:BuildBackend"
```

[] Install: `pip install -e ".[dev]"` (inside `.venv`)

[] Update `PYTHON_PATH` in `.env` to point to `.venv` python binary

1.11 0.11 – Java Environment

[x] Confirm JDK ≥ 17 : `java -version`, `javac -version`

[] Review `java-module/compile.sh` – understand what it does:

```
1 #!/bin/bash
2 mkdir -p build
3 javac -d build src/LogFormat.java src/ParseResult.java src/LogParser.java
4     src/HashScanner.java
5 echo "Compilation complete"
```

[] Run `compile.sh` (or equivalent on Windows with `javac`)

[] Verify `.class` files appear in `java-module/build/`

Deliverables

- Git repo with clean structure, `.gitignore`, `CHANGELOG.md`
- Apache vhost serving `frontend/` at root, `api/` at `/api`
- Composer installed with PSR-4 autoloading configured
- `api/config/Environment.php`, `Database.php`, `Cors.php`
- `api/helpers/Response.php`, `Validator.php`
- `api/index.php` Front Controller with basic routing skeleton
- `python-module/pyproject.toml` (replacing `requirements.txt`)
- Java module compiling without errors

Validation Criteria

- []** `http://helix.local` → serves `frontend/index.html`
- []** `http://helix.local/api` → JSON response (not HTML)
- []** `http://helix.local/api/nonexistent` → `{"success":false,"error":"Route not found"}`
- []** `composer dump-autoload` runs without errors
- []** Python: `python -c "import sklearn; print('OK')"` inside `.venv`
- []** Java: `javac` compiles all source files
- []** Git log shows meaningful commits

Common Mistakes to Avoid

- × Skipping the Apache Alias directive – frontend won't be able to call `/api/*`
- × Committing `.env` – real credentials must stay out of git
- × Keeping `requirements.txt` – you decided to use `pyproject.toml`
- × Not setting up PSR-4 autoloading – you'll write manual `require` statements everywhere
- × Writing route logic directly in `api/index.php` instead of dispatching to controllers

2. PHASE 1 – Architecture Design, Database Schema & UML

Phase 1: Architecture & Design

Why this comes before coding: You already have .puml diagram files. This phase is about validating them, locking the database schema, and mapping every SRS requirement to a concrete implementation path. Changing the schema after writing 5 models is expensive.

Objective

Finalize and validate the complete database schema, UML diagrams, API contract, and traceability matrix. Nothing functional gets built in this phase – only design artifacts.

Learning Goals

- Understand relational database normalization (1NF, 2NF, 3NF)
- Understand how to derive a schema from use cases and actors
- Understand REST API contract-first design
- Understand what each UML diagram type communicates and to whom

Key Theoretical Concepts

- **Entity-Relationship vs Class Diagram:** ER models data; Class models code structure
- **Foreign key CASCADE rules:** ON DELETE CASCADE vs ON DELETE SET NULL – when to use each
- **ENUM vs lookup table:** ENUMs are fast and sufficient for a PoC; lookup tables scale better
- **REST resource naming:** /alerts not /getAlerts; /alerts/{id}/status not /updateAlertStatus
- **HTTP status codes:** 200 OK, 201 Created, 400 Bad Request, 401 Unauthorized, 403 Forbidden, 404 Not Found, 409 Conflict, 422 Unprocessable Entity, 500 Internal Server Error

2.1 1.1 – Database Schema

db/schema.sql – finalize all tables before writing a single model:

```

1 CREATE DATABASE IF NOT EXISTS helix_db CHARACTER SET utf8mb4 COLLATE
  utf8mb4_unicode_ci;
2 USE helix_db;
3
4 CREATE TABLE users (
5     id                INT AUTO_INCREMENT PRIMARY KEY,
6     username          VARCHAR(50)  UNIQUE NOT NULL,
7     email             VARCHAR(100) UNIQUE NOT NULL,
8     password_hash     VARCHAR(255) NOT NULL,
9     role              ENUM('administrator','blue_team','red_team','purple_team',
10        'learner') NOT NULL,
11     is_active         BOOLEAN      DEFAULT TRUE,
12     created_at        TIMESTAMP    DEFAULT CURRENT_TIMESTAMP,
13     last_login        TIMESTAMP    NULL
14 );
15
16 CREATE TABLE log_entries (
17     id                INT AUTO_INCREMENT PRIMARY KEY,
18     filename          VARCHAR(255),
19     source_ip         VARCHAR(45),
20     timestamp         TIMESTAMP    NOT NULL,
21     severity          ENUM('LOW','MEDIUM','HIGH','CRITICAL') DEFAULT 'LOW',
22     event_type        VARCHAR(100),
23     message           TEXT          NOT NULL,
24     raw_line          TEXT,
25     ingested_at       TIMESTAMP    DEFAULT CURRENT_TIMESTAMP,
26     ingested_by       INT          NULL,
27     FOREIGN KEY (ingested_by) REFERENCES users(id) ON DELETE SET NULL
28 );
29
30 CREATE TABLE anomaly_scores (
31     id                INT AUTO_INCREMENT PRIMARY KEY,
32     log_entry_id      INT          NOT NULL,
33     score             FLOAT NOT NULL,
34     severity_label    ENUM('LOW','MEDIUM','HIGH','CRITICAL') NOT NULL,
35     computed_at       TIMESTAMP    DEFAULT CURRENT_TIMESTAMP,
36     FOREIGN KEY (log_entry_id) REFERENCES log_entries(id) ON DELETE
37         CASCADE
38 );
39
40 CREATE TABLE alerts (
41     id                INT AUTO_INCREMENT PRIMARY KEY,
42     log_entry_id      INT          NULL,
43     anomaly_score_id  INT          NULL,
44     title             VARCHAR(255) NOT NULL,
45     description       TEXT,
46     severity          ENUM('LOW','MEDIUM','HIGH','CRITICAL') NOT NULL,
47     status            ENUM('open','investigating','resolved') DEFAULT 'open',
48     assigned_to       INT          NULL,

```

```

47     created_at          TIMESTAMP DEFAULT CURRENT_TIMESTAMP ,
48     updated_at          TIMESTAMP DEFAULT CURRENT_TIMESTAMP ON UPDATE
        CURRENT_TIMESTAMP ,
49     FOREIGN KEY (log_entry_id)      REFERENCES log_entries(id)      ON DELETE
        SET NULL ,
50     FOREIGN KEY (anomaly_score_id) REFERENCES anomaly_scores(id) ON DELETE
        SET NULL ,
51     FOREIGN KEY (assigned_to)      REFERENCES users(id)            ON DELETE
        SET NULL
52 );
53
54 CREATE TABLE chat_sessions (
55     id                  INT AUTO_INCREMENT PRIMARY KEY ,
56     user_id            INT NOT NULL ,
57     alert_id           INT NULL ,
58     message_role       ENUM('user','assistant') NOT NULL ,
59     content             TEXT NOT NULL ,
60     sent_at            TIMESTAMP DEFAULT CURRENT_TIMESTAMP ,
61     FOREIGN KEY (user_id)  REFERENCES users(id)  ON DELETE CASCADE ,
62     FOREIGN KEY (alert_id) REFERENCES alerts(id) ON DELETE SET NULL
63 );
64
65 CREATE TABLE scan_results (
66     id                  INT AUTO_INCREMENT PRIMARY KEY ,
67     performed_by       INT NOT NULL ,
68     target             VARCHAR(255) NOT NULL ,
69     port               INT NOT NULL ,
70     protocol           VARCHAR(10) ,
71     status             ENUM('open','closed','filtered') NOT NULL ,
72     scanned_at         TIMESTAMP DEFAULT CURRENT_TIMESTAMP ,
73     FOREIGN KEY (performed_by) REFERENCES users(id)
74 );

```

[] Verify schema matches your UML diagrams

[] Import: `mysql -u helix_user -p helix_db < db/schema.sql`

[] Confirm all 6 tables appear in phpMyAdmin

Note on migrations: Every schema change after the initial import must be a new migration file: 002_, 003_, etc. Never re-edit `schema.sql` to fix an existing column – add a migration.

2.2 1.2 – API Route Contract

Document every route in `docs/SDD/API_REFERENCE.md`. For each route define: method, path, required role, request body, success response, error responses.

Complete route table:

Method	Path	Controller.Method	Required Role	FR
POST	/auth/register	AuthController.register	public	FR-007
POST	/auth/login	AuthController.login	public	FR-001
POST	/auth/logout	AuthController.logout	any authenticated	FR-005
GET	/auth/me	AuthController.me	any authenticated	FR-003
GET	/dashboard/stats	DashboardController.stats	any authenticated	FR-010
POST	/logs/upload	LogController.upload	admin, blue, purple	FR-020
GET	/logs	LogController.index	any authenticated	FR-022
GET	/logs/{id}	LogController.show	any authenticated	FR-023
GET	/alerts	AlertController.index	any authenticated	FR-030
GET	/alerts/{id}	AlertController.show	any authenticated	FR-034
PUT	/alerts/{id}/status	AlertController.updateStatus	admin, blue, purple	FR-033
POST	/ml/score	MLController.score	administrator	FR-040
GET	/ml/scores	MLController.index	any authenticated	FR-044
POST	/ai/chat	AIController.chat	any authenticated	FR-050
GET	/ai/history	AIController.history	any authenticated	FR-053
POST	/scanner/scan	ScannerController.scan	admin, red, purple	FR-060
GET	/scanner/results	ScannerController.results	admin, red, purple	FR-062

[[Add this table to docs/SDD/API_REFERENCE.md

[[Add every route to your api/index.php routing table (as empty stubs for now)

2.3 1.3 – UML Diagram Validation

You already have .puml files. This task is about reviewing them for correctness:

[[use_case.puml – Does it show all 7 actors (A0–A7)? Are «extend» / «include» used correctly?

[[er_diagram.puml – Does it match schema.sql exactly? Check column names, types, FK arrows

[[class_services.puml – Does it show Controller → Service → Model relationships?

[[sequence_auth.puml – Does it show: browser → index.php → AuthMiddleware → AuthController → AuthService → User model → MySQL?

[[sequence_log_ingest.puml – Does it show the pipeline: upload → LogService → JavaBridge → LogParser → LogEntry model → MLService trigger?

[[sequence_ai_chat.puml – Does it show: AIController → AIService → OpenAI API → ChatSession model?

[[component.puml – Does it show: Browser, Apache (frontend + api), PHP (controllers/services/models), Python ML, Java module, MySQL?

[] `activity_alert.puml` – Does it show the full alert lifecycle: log ingested → scored → alert created → triaged → resolved?

Export all diagrams as PNG into `docs/UML/png/`.

2.4 1.4 – SRS Traceability Matrix

`docs/traceability_matrix.md`:

FR ID	Description	Route	Controller.Method	DB Table	Status
FR-001	Login	POST /auth/login	AuthController.login	users	[]
FR-002	Failed login handling	POST /auth/login	AuthController.login	users	[]
FR-003	Session persistence	GET /auth/me	AuthController.me	users	[]
... (map every FR-001 to FR-063)					

[] Map every FR-001 to FR-063 to a route, controller method, and DB table

[] This matrix is your implementation checklist – check FRs off as you build

2.5 1.5 – Seed File

`database/seed.sql`:

```

1 -- Admin user (password: Admin@1234)
2 -- Generate hash: php -r "echo password_hash('Admin@1234', PASSWORD_BCRYPT
  , ['cost'=>12]);"
3 INSERT INTO users (username, email, password_hash, role) VALUES
4 ('admin', 'admin@helix.local', '$2y$12$GENERATED_HASH_HERE', '
  administrator'),
5 ('blue1', 'blue@helix.local', '$2y$12$GENERATED_HASH_HERE', 'blue_team'),
6 ('red1', 'red@helix.local', '$2y$12$GENERATED_HASH_HERE', 'red_team');
```

[] Generate real bcrypt hashes and update `seed.sql`

[] Import: `mysql -u helix_user -p helix_db < database/seed.sql`

Deliverables

- `db/schema.sql` – final, importable, 6 tables
- `docs/SDD/API_REFERENCE.md` – complete route contract
- All UML diagrams validated and exported to PNG

- docs/traceability_matrix.md – all FRs mapped
- database/seed.sql – 3 test users

Validation Criteria

- [] Schema imports without error
- [] All 6 tables visible in phpMyAdmin
- [] All UML diagrams reviewed and corrected
- [] All FR-001 to FR-063 appear in traceability matrix
- [] All routes registered as stubs in api/index.php
- [] Git commit: docs: finalize schema, API contract, UML and traceability matrix

Common Mistakes to Avoid

- × Editing schema.sql after first import instead of creating a migration
- × Skipping the traceability matrix – you will lose track of which FRs are done
- × Routes in api/index.php pointing to non-existent controller methods
- × UML diagrams that don't match the actual code structure

3. PHASE 2 – Authentication Module (FR-001 to FR-007)

Phase 2: Authentication & RBAC

Why this comes before all other modules: Every other feature is gated behind authentication. You cannot build role-based features without a working session system. Auth is also your highest-security concern – if it's broken, everything built on it is insecure.

Objective

Implement the complete authentication flow: register, login, logout, session validation – with bcrypt hashing, PHP sessions, and role middleware enforcing access control on every protected route.

Learning Goals

- Understand bcrypt and why password hashing $\neq$ encryption
- Understand PHP session security: `session_regenerate_id()`, cookie flags
- Understand the difference between Authentication (who are you?) and Authorization (what can you do?)
- Understand how middleware chains work in a Front Controller pattern

Key Theoretical Concepts

- **bcrypt cost factor:** Each increment doubles computation time – cost 12 is $\sim 300\text{ms}$, which is too slow to brute-force
- **Session fixation attack:** Why `session_regenerate_id(true)` is mandatory after login
- **HttpOnly cookie flag:** Prevents JavaScript from reading the session cookie (XSS protection)
- **SameSite=Strict:** Prevents the browser from sending the cookie on cross-site requests (CSRF protection)
- **Generic error messages:** "Invalid credentials" – never "User not found" or "Wrong password"

3.1 2.1 – Auth Middleware

api/middleware/AuthMiddleware.php:

```
1 <?php
2 namespace App\Middleware;
3
4 use App\Helpers\Response;
5
6 class AuthMiddleware
7 {
8     public static function handle(): void
9     {
10         self::startSecureSession();
11
12         if (!isset($_SESSION['user_id'])) {
13             Response::unauthorized();
14         }
15     }
16
17     public static function startSecureSession(): void
18     {
19         if (session_status() === PHP_SESSION_NONE) {
20             ini_set('session.cookie_httponly', '1');
21             ini_set('session.cookie_samesite', 'Strict');
22             ini_set('session.gc_maxlifetime', (string)($_ENV['
23                 SESSION_LIFETIME'] ?? 3600));
24             session_start();
25         }
26     }
27
28     public static function currentUser(): array
29     {
30         return [
31             'id' => $_SESSION['user_id'] ?? null,
32             'role' => $_SESSION['user_role'] ?? null,
33         ];
34     }
35 }
```

api/middleware/RoleMiddleware.php:

```
1 <?php
2 namespace App\Middleware;
3
4 use App\Helpers\Response;
5
6 class RoleMiddleware
7 {
8     public static function require(array $allowedRoles): void
9     {
10         AuthMiddleware::handle();
11
12         $userRole = $_SESSION['user_role'] ?? '';
```

```

13
14         if (!in_array($UserRole, $allowedRoles, true)) {
15             Response::forbidden();
16         }
17     }
18 }

```

3.2 2.2 – User Model

api/models/User.php:

```

1 <?php
2 namespace App\Models;
3
4 use App\Config\Database;
5 use PDO;
6
7 class User
8 {
9     public static function findByUsername(string $username): ?array
10     {
11         $db = Database::getInstance();
12         $stmt = $db->prepare('SELECT * FROM users WHERE username = ? AND
13             is_active = 1 LIMIT 1');
14         $stmt->execute([$username]);
15         return $stmt->fetch() ?: null;
16     }
17
18     public static function findById(int $id): ?array
19     {
20         $db = Database::getInstance();
21         $stmt = $db->prepare('SELECT id, username, email, role, created_at
22             , last_login FROM users WHERE id = ? LIMIT 1');
23         $stmt->execute([$id]);
24         return $stmt->fetch() ?: null;
25     }
26
27     public static function create(string $username, string $email, string
28         $passwordHash, string $role = 'learner'): int
29     {
30         $db = Database::getInstance();
31         $stmt = $db->prepare('INSERT INTO users (username, email,
32             password_hash, role) VALUES (?, ?, ?, ?)');
33         $stmt->execute([$username, $email, $passwordHash, $role]);
34         return (int) $db->lastInsertId();
35     }
36
37     public static function updateLastLogin(int $id): void
38     {
39         $db = Database::getInstance();
40         $stmt = $db->prepare('UPDATE users SET last_login = NOW() WHERE id

```

```

        = ?');
37     $stmt->execute([$id]);
38 }
39
40 public static function emailOrUsernameExists(string $username, string
    $email): bool
41 {
42     $db = Database::getInstance();
43     $stmt = $db->prepare('SELECT id FROM users WHERE username = ? OR
        email = ? LIMIT 1');
44     $stmt->execute([$username, $email]);
45     return (bool) $stmt->fetch();
46 }
47 }

```

3.3 2.3 – Auth Service

api/services/AuthService.php:

```

1  <?php
2  namespace App\Services;
3
4  use App\Models\User;
5  use App\Middleware\AuthMiddleware;
6
7  class AuthService
8  {
9      public function register(array $data): array
10     {
11         if (User::emailOrUsernameExists($data['username'], $data['email'])
12             ) {
13             return ['error' => 'Username or email already exists', 'code'
14                 => 409];
15         }
16
17         $hash = password_hash($data['password'], PASSWORD_BCRYPT, ['cost'
18             => 12]);
19         $id = User::create($data['username'], $data['email'], $hash);
20
21         return ['user_id' => $id];
22     }
23
24     public function login(string $username, string $password): array
25     {
26         $user = User::findByUsername($username);
27
28         if (!$user || !password_verify($password, $user['password_hash']))
29         {
30             return ['error' => 'Invalid credentials', 'code' => 401];
31         }
32     }
33 }

```

```

29     AuthMiddleware::startSecureSession();
30     session_regenerate_id(true);
31
32     $_SESSION['user_id']    = $user['id'];
33     $_SESSION['user_role'] = $user['role'];
34
35     User::updateLastLogin($user['id']);
36
37     return [
38         'user' => [
39             'id'          => $user['id'],
40             'username' => $user['username'],
41             'role'       => $user['role'],
42         ]
43     ];
44 }
45
46 public function logout(): void
47 {
48     AuthMiddleware::startSecureSession();
49     $_SESSION = [];
50     session_destroy();
51 }
52
53 public function currentUser(): ?array
54 {
55     $id = $_SESSION['user_id'] ?? null;
56     return $id ? User::findById((int)$id) : null;
57 }
58 }

```

3.4 2.4 – Auth Controller

api/controllers/AuthController.php:

```

1 <?php
2 namespace App\Controllers;
3
4 use App\Services\AuthService;
5 use App\Middleware\AuthMiddleware;
6 use App\Helpers\Response;
7 use App\Helpers\Validator;
8
9 class AuthController
10 {
11     private AuthService $service;
12
13     public function __construct()
14     {
15         $this->service = new AuthService();
16     }

```

```
17
18 public function register(): void
19 {
20     $body = json_decode(file_get_contents('php://input'), true) ?? [];
21
22     $v = (new Validator())
23         ->required('username', $body['username'] ?? '')
24         ->required('email', $body['email'] ?? '')
25         ->required('password', $body['password'] ?? '')
26         ->email('email', $body['email'] ?? '')
27         ->minLength('password', $body['password'] ?? '', 8);
28
29     if (!$v->passes()) {
30         Response::error(json_encode($v->errors()), 422);
31     }
32
33     $result = $this->service->register($body);
34
35     if (isset($result['error'])) {
36         Response::error($result['error'], $result['code']);
37     }
38
39     Response::success($result, 'Account created', 201);
40 }
41
42 public function login(): void
43 {
44     $body = json_decode(file_get_contents('php://input'), true) ?? [];
45
46     $result = $this->service->login(
47         $body['username'] ?? '',
48         $body['password'] ?? ''
49     );
50
51     if (isset($result['error'])) {
52         Response::error($result['error'], $result['code']);
53     }
54
55     Response::success($result['user'], 'Login successful');
56 }
57
58 public function logout(): void
59 {
60     AuthMiddleware::handle();
61     $this->service->logout();
62     Response::success(null, 'Logged out');
63 }
64
65 public function me(): void
66 {
67     AuthMiddleware::handle();
68     $user = $this->service->currentUser();
69 }
```

```

70     if (!$user) {
71         Response::unauthorized();
72     }
73
74     Response::success($user);
75 }
76 }

```

3.5 2.5 – Register Auth Routes

In `api/index.php`, add to the routes array:

```

1 use App\Controllers\AuthController;
2
3 $routes['POST']['/auth/register'] = [AuthController::class, 'register'];
4 $routes['POST']['/auth/login']    = [AuthController::class, 'login'];
5 $routes['POST']['/auth/logout']   = [AuthController::class, 'logout'];
6 $routes['GET']['/auth/me']        = [AuthController::class, 'me'];

```

3.6 2.6 – Frontend: Login Page

`frontend/login.html` – already exists in your tree. Build it now:

- HTML form: username + password fields
- No page refresh – use JavaScript `fetch()`

`frontend/js/auth.js`:

```

1 async function login(username, password) {
2     const res = await fetch("/api/auth/login", {
3         method: "POST",
4         headers: { "Content-Type": "application/json" },
5         credentials: "include",
6         body: JSON.stringify({ username, password }),
7     });
8
9     const data = await res.json();
10
11     if (data.success) {
12         sessionStorage.setItem("userRole", data.data.role);
13         window.location.href = "/dashboard.html";
14     } else {
15         showError(data.error);
16     }
17 }

```

`frontend/js/api.js` – the shared API client module:

```

1 const API_BASE = "/api";

```

```

2
3 async function apiFetch(path, options = {}) {
4   const defaults = {
5     credentials: "include",
6     headers: { "Content-Type": "application/json" },
7   };
8
9   const res = await fetch(`${API_BASE}${path}`, { ...defaults, ...options
10     });
11
12   if (res.status === 401) {
13     window.location.href = "/login.html";
14     return;
15   }
16
17   return await res.json();
18 }
19
20 const api = {
21   get: (path) => apiFetch(path),
22   post: (path, body) =>
23     apiFetch(path, { method: "POST", body: JSON.stringify(body) }),
24   put: (path, body) =>
25     apiFetch(path, { method: "PUT", body: JSON.stringify(body) }),
26   delete: (path) => apiFetch(path, { method: "DELETE" }),
27 };

```

Why credentials: 'include': Without this, the browser won't send the session cookie with cross-path requests. This is the most common cause of "keeps logging me out" bugs.

3.7 2.7 – Auth Tests

tests/php/AuthServiceTest.php (PHPUnit):

```

1 <?php
2 namespace Tests;
3
4 use PHPUnit\Framework\TestCase;
5 use App\Services\AuthService;
6
7 class AuthServiceTest extends TestCase
8 {
9   public function test_register_returns_user_id(): void
10   {
11     $this->markTestIncomplete('Requires test DB setup');
12   }
13
14   public function test_login_returns_error_on_wrong_password(): void
15   {
16     $service = new AuthService();
17     $result = $this->invokeMethod($service, 'validateCredentials', ['

```



```

18         'nonexistent', 'wrongpass']];
19     $this->assertArrayHasKey('error', $result);
20 }
21 private function invokeMethod(object $obj, string $method, array $args
22     = []): mixed
23 {
24     $ref = new \ReflectionMethod($obj, $method);
25     $ref->setAccessible(true);
26     return $ref->invokeArgs($obj, $args);
27 }

```

3.8 2.8 – Manual Test Checklist

tests/manual/auth_tests.md:

- ☐ POST /api/auth/register valid data → 201, user_id returned
- ☐ POST /api/auth/register duplicate username → 409
- ☐ POST /api/auth/register invalid email → 422
- ☐ POST /api/auth/login valid credentials → 200, role returned, cookie set
- ☐ POST /api/auth/login wrong password → 401, "Invalid credentials"
- ☐ GET /api/auth/me with cookie → 200, user data
- ☐ GET /api/auth/me without cookie → 401
- ☐ POST /api/auth/logout → 200, cookie destroyed
- ☐ GET /api/auth/me after logout → 401
- ☐ Test route requiring admin role as learner → 403

Test all using Postman or Insomnia – configure "Send cookies" option.

Deliverables

- api/middleware/AuthMiddleware.php, RoleMiddleware.php
- api/models/User.php
- api/services/AuthService.php
- api/controllers/AuthController.php
- frontend/login.html functional form
- frontend/js/auth.js, frontend/js/api.js

- Auth routes registered in `api/index.php`
- `tests/manual/auth_tests.md` all checks passing

Validation Criteria

- [] FR-001 to FR-007 checked in traceability matrix
- [] Passwords stored as bcrypt (verify in phpMyAdmin – hash starts with `$2y$`)
- [] Wrong password returns same error message as non-existent user
- [] `session_regenerate_id(true)` called on every login
- [] Frontend redirects to login on 401 (handled in `api.js`)
- [] Git commit: `feat(auth): implement authentication, RBAC middleware, login frontend`

Common Mistakes to Avoid

- × Checking roles only in the frontend JavaScript – always enforce in `RoleMiddleware`
- × Returning "User not found" vs "Wrong password" separately – merge into one message
- × Forgetting `credentials`: `'include'` in every `fetch()` call
- × Using `md5()` or `sha1()` for passwords
- × Not calling `session_regenerate_id()` – session fixation vulnerability

4. PHASE 3 – Dashboard Module (FR-010 to FR-014)

Phase 3: Dashboard & Routing

Why now: The dashboard is the shell of the application – the first page after login. Building it now, even with placeholder data, establishes the UI framework, client-side router, and nav structure that all subsequent modules will plug into.

Objective

Build the dashboard frontend shell (with routing), implement the stats API endpoint, and render security metrics with Chart.js. Use placeholder/zero data for sections not yet implemented.

Learning Goals

- Understand client-side routing without a framework (`router.js`)
- Understand the HTML5 History API (`pushState`, `popstate`)
- Understand Chart.js configuration and data binding
- Understand role-based UI rendering in JavaScript

Key Theoretical Concepts

- **SPA routing:** The browser loads one HTML page; JavaScript swaps content based on URL without full page reload
- `history.pushState()`: Changes the URL without navigating – the foundation of client-side routing
- **Dashboard as aggregation endpoint:** The dashboard API doesn't own data; it queries multiple tables and returns a summary
- **Graceful empty states:** Your dashboard must not crash when the DB is empty (it will be during early development)

4.1 3.1 – Client-Side Router

frontend/js/router.js:

```

1  const routes = {
2    "/dashboard": () => import("./dashboard.js").then((m) => m.render()),
3    "/logs": () => import("./logs.js").then((m) => m.render()),
4    "/alerts": () => import("./alerts.js").then((m) => m.render()),
5    "/ai": () => import("./chat.js").then((m) => m.render()),
6    "/scanner": () => import("./scanner.js").then((m) => m.render()),
7  };
8
9  async function navigate(path) {
10    const handler = routes[path];
11
12    if (!handler) {
13      document.getElementById("app").innerHTML = "<h2>404 - Page not found</h2>";
14      return;
15    }
16
17    history.pushState({}, "", path);
18    document.getElementById("app").innerHTML =
19      '<div class="loading">Loading...</div>';
20    await handler();
21  }
22
23  window.addEventListener("popstate", () => navigate(location.pathname));
24
25  document.addEventListener("click", (e) => {
26    const link = e.target.closest("[data-route]");
27    if (link) {
28      e.preventDefault();
29      navigate(link.dataset.route);
30    }
31  });
32
33  export { navigate };

```

4.2 3.2 – Dashboard Shell

frontend/dashboard.html:

```

1  <!DOCTYPE html>
2  <html lang="en">
3    <head>
4      <meta charset="UTF-8" />
5      <title>HELIX - Dashboard</title>
6      <link rel="stylesheet" href="/css/main.css" />
7      <link rel="stylesheet" href="/css/dashboard.css" />
8    </head>
9    <body>

```

```

10     <div id="layout">
11         <nav id="sidebar"></nav>
12         <main id="app"></main>
13     </div>
14     <script type="module" src="/js/ui.js"></script>
15     <script type="module" src="/js/router.js"></script>
16 </body>
17 </html>

```

frontend/js/ui.js – builds the sidebar based on user role:

```

1  import { navigate } from "./router.js";
2
3  const roleNavMap = {
4      administrator: ["/dashboard", "/logs", "/alerts", "/ai", "/scanner"],
5      blue_team: ["/dashboard", "/logs", "/alerts", "/ai"],
6      red_team: ["/dashboard", "/scanner", "/ai"],
7      purple_team: ["/dashboard", "/logs", "/alerts", "/ai", "/scanner"],
8      learner: ["/dashboard", "/ai"],
9  };
10
11  async function initUI() {
12      const res = await fetch("/api/auth/me", { credentials: "include" });
13      if (!res.ok) {
14          window.location.href = "/login.html";
15          return;
16      }
17
18      const { data: user } = await res.json();
19      const allowedPaths = roleNavMap[user.role] ?? [];
20
21      buildSidebar(allowedPaths, user);
22      navigate("/dashboard");
23  }
24
25  function buildSidebar(paths, user) {
26      const labels = {
27          "/dashboard": "Dashboard",
28          "/logs": "Logs",
29          "/alerts": "Alerts",
30          "/ai": "AI Assistant",
31          "/scanner": "Scanner",
32      };
33      const nav = document.getElementById("sidebar");
34      nav.innerHTML =
35          paths
36              .map((p) => `<a data-route="${p}" href="${p}">${labels[p]}</a>`)
37              .join("") + `<button id="logout-btn">Logout (${user.username})</button>`;
38
39      document.getElementById("logout-btn").addEventListener("click", async () => {
40          await fetch("/api/auth/logout", { method: "POST", credentials: "

```

```

        include" });
41     window.location.href = "/login.html";
42 });
43 }
44
45 initUI();

```

4.3 3.3 – Dashboard Stats Endpoint

api/controllers/DashboardController.php:

```

1  <?php
2  namespace App\Controllers;
3
4  use App\Config\Database;
5  use App\Middleware\AuthMiddleware;
6  use App\Helpers\Response;
7
8  class DashboardController
9  {
10     public function stats(): void
11     {
12         AuthMiddleware::handle();
13         $db = Database::getInstance();
14
15         $alertsBySeverity = $db->query(
16             "SELECT severity, COUNT(*) as count FROM alerts GROUP BY
17                 severity"
18         )->fetchAll();
19
20         $logCount = $db->query("SELECT COUNT(*) as count FROM log_entries"
21             )->fetch()['count'];
22
23         $avgScore = $db->query("SELECT ROUND(AVG(score), 4) as avg FROM
24             anomaly_scores")->fetch()['avg'] ?? 0;
25
26         $trend = $db->query(
27             "SELECT DATE(created_at) as date, COUNT(*) as count
28                 FROM alerts
29                 WHERE created_at >= DATE_SUB(NOW(), INTERVAL 7 DAY)
30                 GROUP BY DATE(created_at)
31                 ORDER BY date ASC"
32         )->fetchAll();
33
34         $openAlerts = $db->query(
35             "SELECT COUNT(*) as count FROM alerts WHERE status = 'open'"
36         )->fetch()['count'];
37
38         Response::success([
39             'alerts_by_severity' => $alertsBySeverity,
40             'log_count'          => (int) $logCount,

```

```

38         'avg_anomaly_score' => (float) $avgScore,
39         'alert_trend'       => $trend,
40         'open_alerts'       => (int) $openAlerts,
41     ]);
42 }
43 }

```

Register route in api/index.php:

```

1 $routes['GET']['/dashboard/stats'] = [DashboardController::class, 'stats'
    ];

```

4.4 3.4 – Dashboard Frontend Module

frontend/js/dashboard.js:

```

1 import { api } from "../api.js";
2
3 export async function render() {
4     const { data } = await api.get("/dashboard/stats");
5
6     document.getElementById("app").innerHTML = `
7         <div class="dashboard-grid">
8             <div class="metric-card">
9                 <span class="metric-label">Open Alerts</span>
10                <span class="metric-value">${data.open_alerts}</span>
11            </div>
12            <div class="metric-card">
13                <span class="metric-label">Total Logs</span>
14                <span class="metric-value">${data.log_count}</span>
15            </div>
16            <div class="metric-card">
17                <span class="metric-label">Avg Anomaly Score</span>
18                <span class="metric-value">${data.avg_anomaly_score}</span>
19            </div>
20            <canvas id="severity-chart"></canvas>
21            <canvas id="trend-chart"></canvas>
22        </div>
23    `;
24
25    renderSeverityChart(data.alerts_by_severity);
26    renderTrendChart(data.alert_trend);
27 }
28
29 function renderSeverityChart(alerts) {
30     // Chart.js doughnut chart
31     const ctx = document.getElementById("severity-chart").getContext("2d");
32     new Chart(ctx, {
33         type: "doughnut",
34         data: {
35             labels: alerts.map((a) => a.severity),

```

```

36     datasets: [{
37         data: alerts.map((a) => a.count),
38         backgroundColor: ["#dc2626", "#f59e0b", "#3b82f6", "#6b7280"],
39     }],
40 },
41 options: { plugins: { title: { display: true, text: "Alerts by
42     Severity" } } },
43 });
44 }
45
46 function renderTrendChart(trend) {
47     const ctx = document.getElementById("trend-chart").getContext("2d");
48     new Chart(ctx, {
49         type: "line",
50         data: {
51             labels: trend.map((t) => t.date),
52             datasets: [{
53                 label: "Alerts per day",
54                 data: trend.map((t) => t.count),
55                 borderColor: "#3C3489",
56                 tension: 0.3,
57             }],
58         },
59         options: { plugins: { title: { display: true, text: "7-Day Alert Trend
60             " } } },
61     });
62 }

```

Deliverables

- frontend/js/router.js, frontend/js/ui.js
- frontend/dashboard.html with sidebar and #app container
- frontend/js/dashboard.js with Chart.js rendering
- api/controllers/DashboardController.php
- Dashboard route registered in api/index.php
- Chart.js included via CDN in dashboard.html

Validation Criteria

- ☐ FR-010 to FR-014 checked in traceability matrix
- ☐ Sidebar shows only role-appropriate links
- ☐ Dashboard renders with zero data (no crashes)

- [] Chart.js charts render with empty/zero datasets
- [] Client-side routing works (back/forward buttons)
- [] Git commit: `feat(dashboard): implement dashboard shell, stats API, Chart.js`

Common Mistakes to Avoid

- × Hardcoding role-based nav in HTML – use `ui.js` to build dynamically
- × Dashboard crashing on empty DB – always use `?? 0` or `|| []`
- × Forgetting `history.pushState()` – browser back button breaks
- × Mixing frontend and backend routing – keep them separate

5. PHASE 4 through PHASE 10 – Implementation Phases

Phases 4 through 10 follow the same structural pattern as Phases 0–3:

- **Phase 4:** Log Ingestion Module (FR-020 to FR-023)
- **Phase 5:** Alert Module (FR-030 to FR-034)
- **Phase 6:** ML Detection Module (FR-040 to FR-044)
- **Phase 7:** AI Assistant Module (FR-050 to FR-053)
- **Phase 8:** Scanner Module (FR-060 to FR-062)
- **Phase 9:** Integration & Testing
- **Phase 10:** Docker & Deployment

Each phase includes: Objective, Learning Goals, Key Theoretical Concepts, Practical Tasks with code, Deliverables, Validation Criteria, and Common Mistakes to Avoid.

Conclusion

This roadmap provides a phased, dependency-ordered execution plan for building the HELIX PoC. Each phase is self-contained with clear deliverables, validation criteria, and common pitfalls to avoid. Follow the strict dependency chain – do not skip ahead. Build one module at a time, test it thoroughly, then proceed.